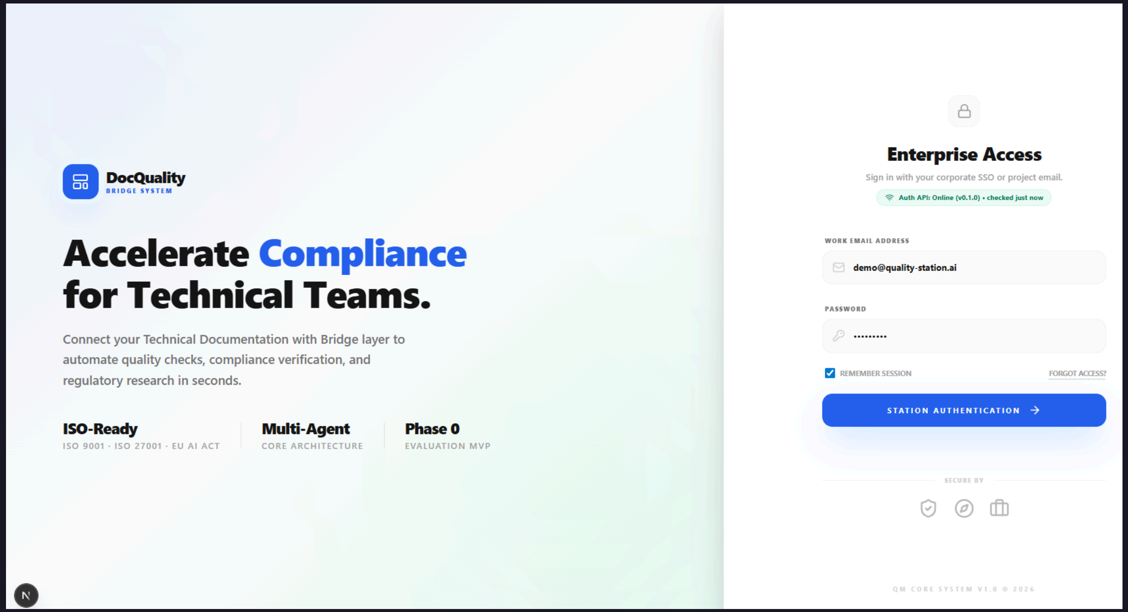
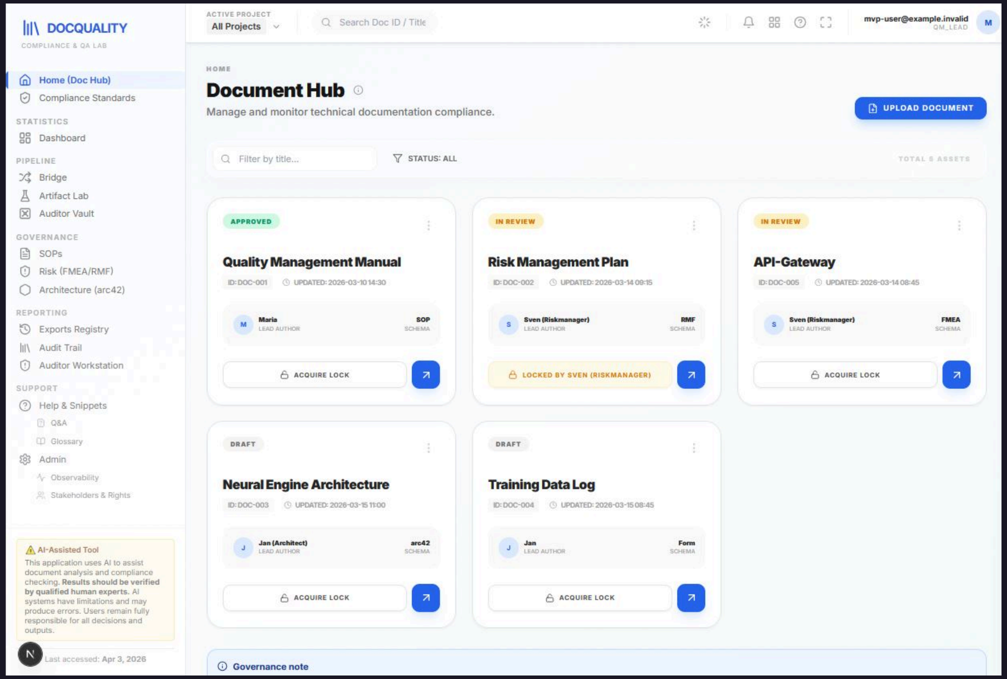
Documentation Quality Compliance Checker

Ilona Brinkmeier · Wiebke Meyer · Carol Willing



Problem

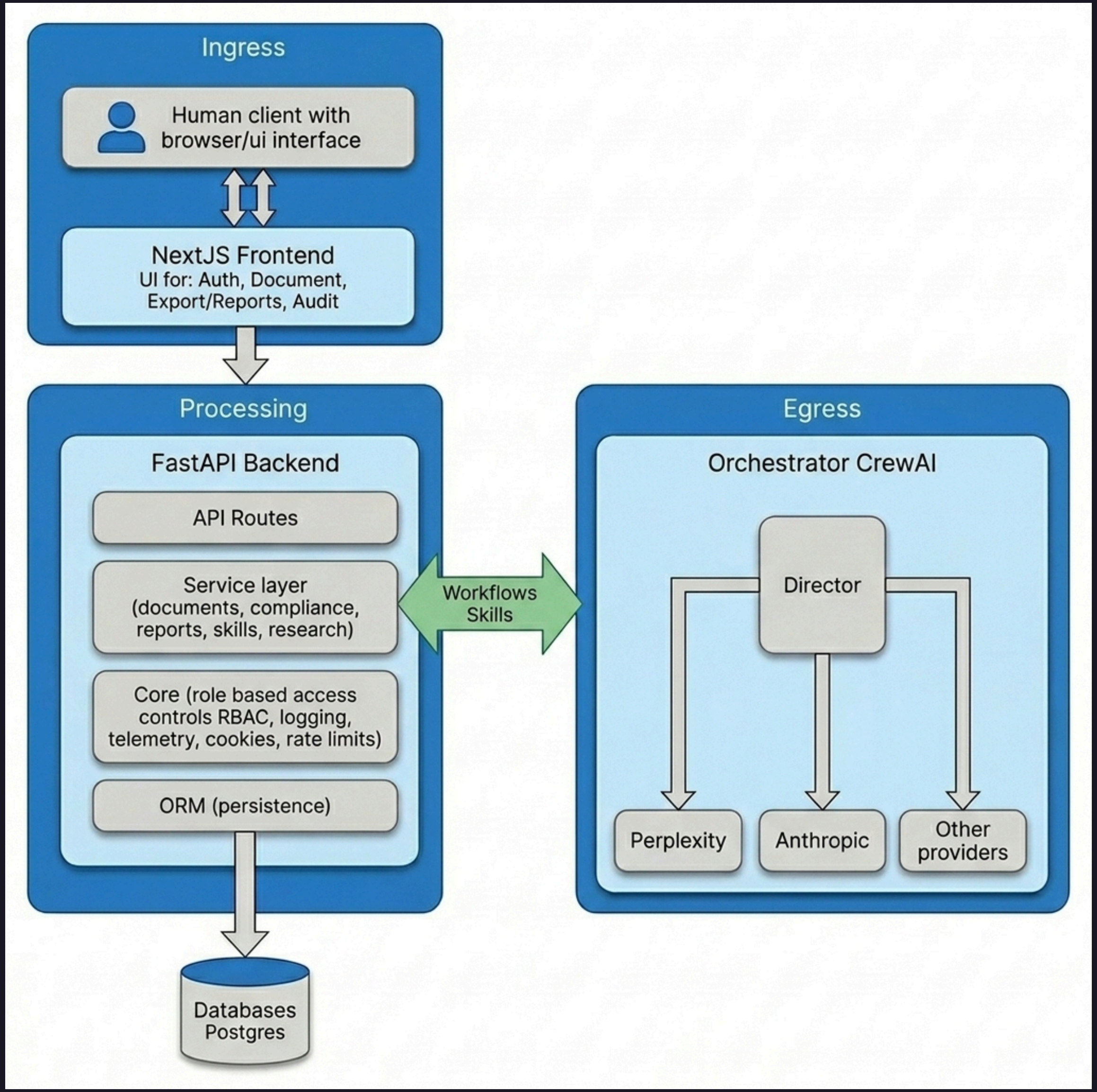
Software teams in regulated or audit-heavy environments (healthcare, fintech, enterprise SaaS or critical infrastructure) often lose significant time during releases because documentation quality and compliance checks are manual, inconsistent and late in the delivery cycle.



Initial solution and audit scope

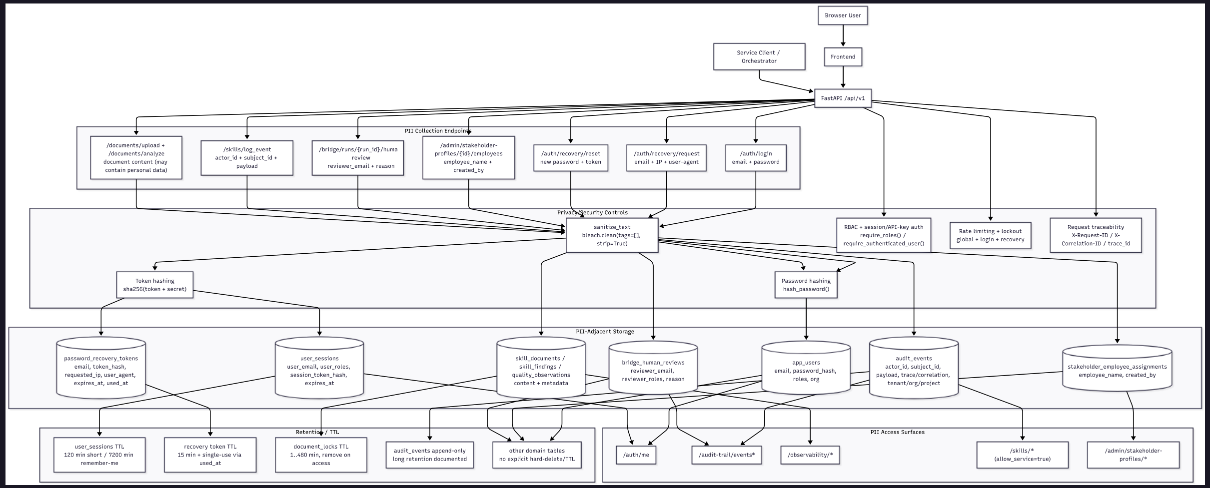
The **Doc Quality Compliance Checker** is a structured, workflow-oriented system that:

- Checks technical documents against governance and quality standards
- Improves consistency across SOP, architecture, and risk artifacts
- Shortens review cycles for QA, compliance, and audit teams
- Surfaces release-risk gaps earlier in the delivery cycle
- Improves traceability for approvals and governance decisions



High-level architecture

- Human operator
- Next.js frontend
- FastAPI backend
- PostgreSQL database
- Orchestrator and external agents
- Excellent documentation and production software engineering practices
- github.com/llobe/doc_quality_compliance_check



Privacy-focused audit

View audit report →

- End-to-end investigation of privacy risks across the stack
- User accounts, roles, and session data (GDPR-relevant)
- Document content and audit trails with business and personal data
- External LLM egress and telemetry expand the trust boundary

Top privacy risks

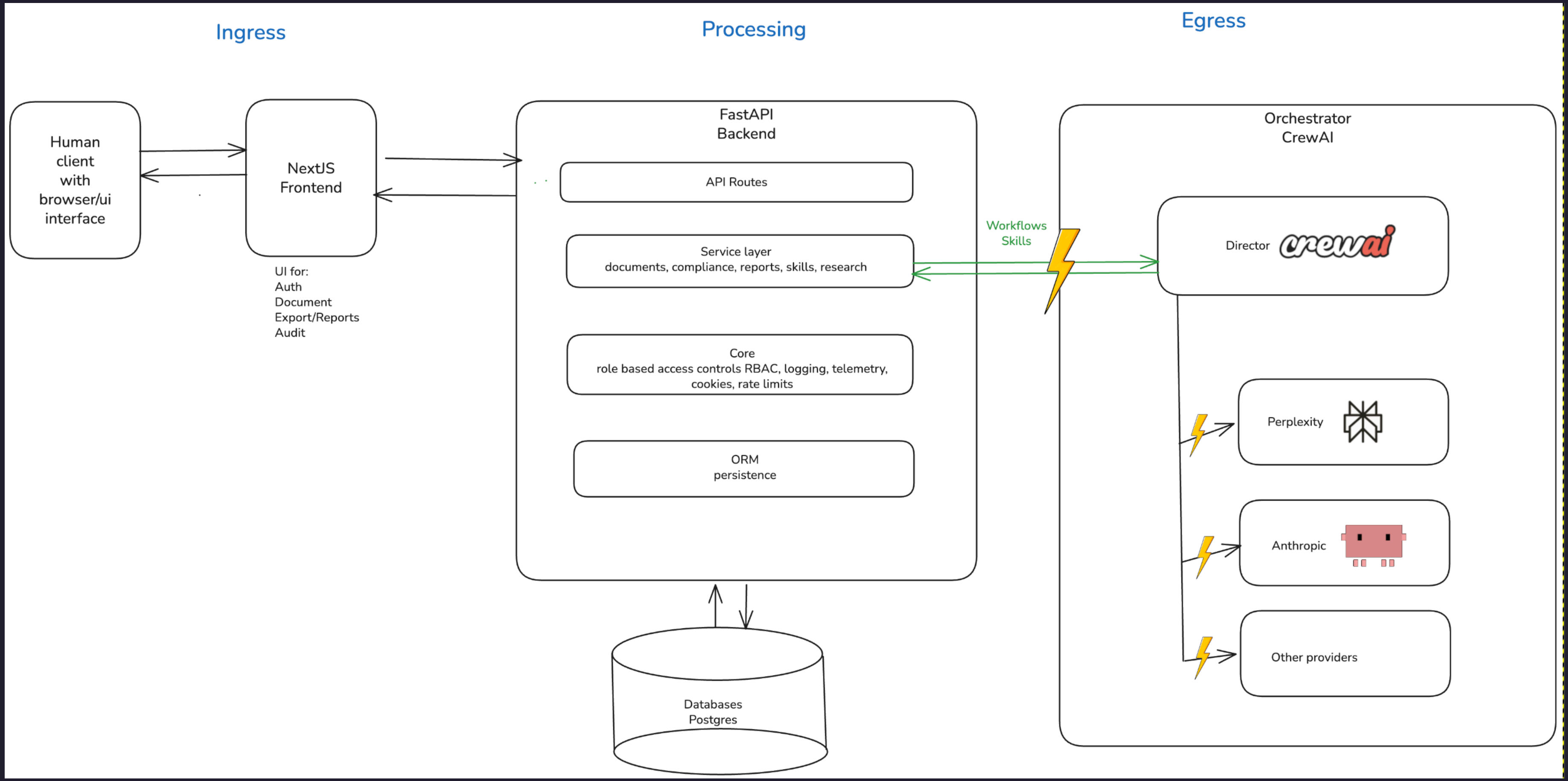
Priorities

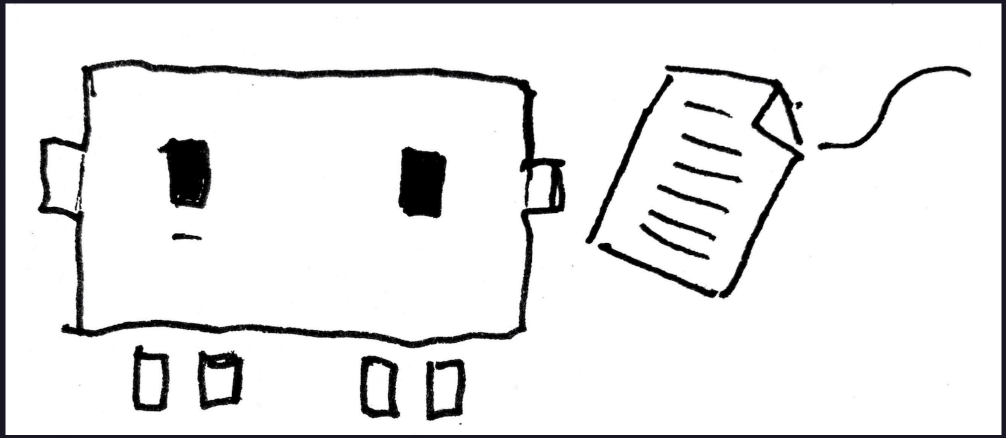
- Egress traffic flow data to director and external models
- Application telemetry and workflow tracing
- Role-based access controls and GDPR compliance

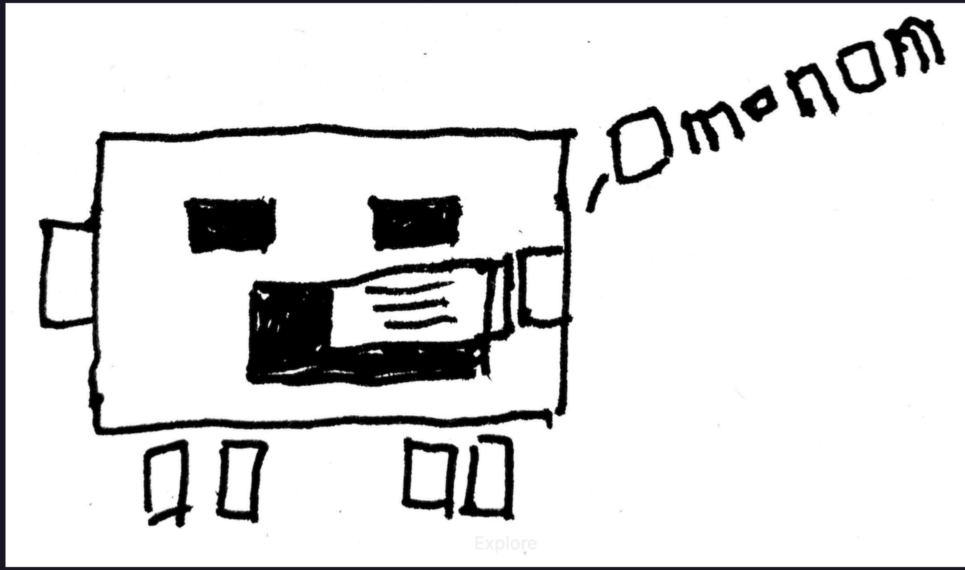
Up next: In-depth risk analysis

- Sensitive data
- Why the risk matters
- Priority of the risk
- **Mitigations** for each risk

Egress exposes privacy data

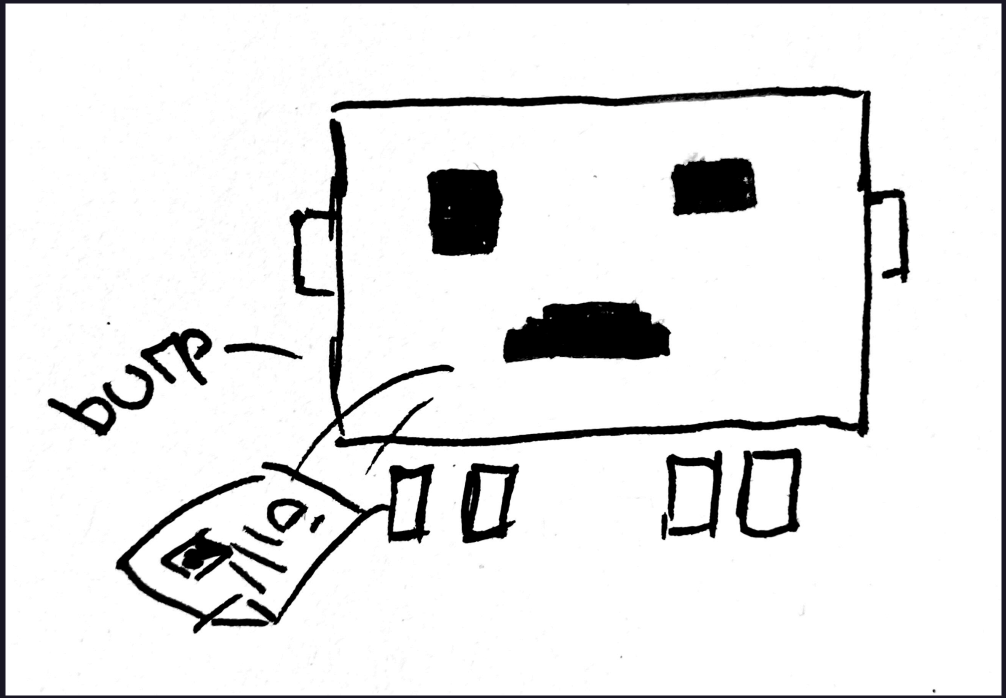






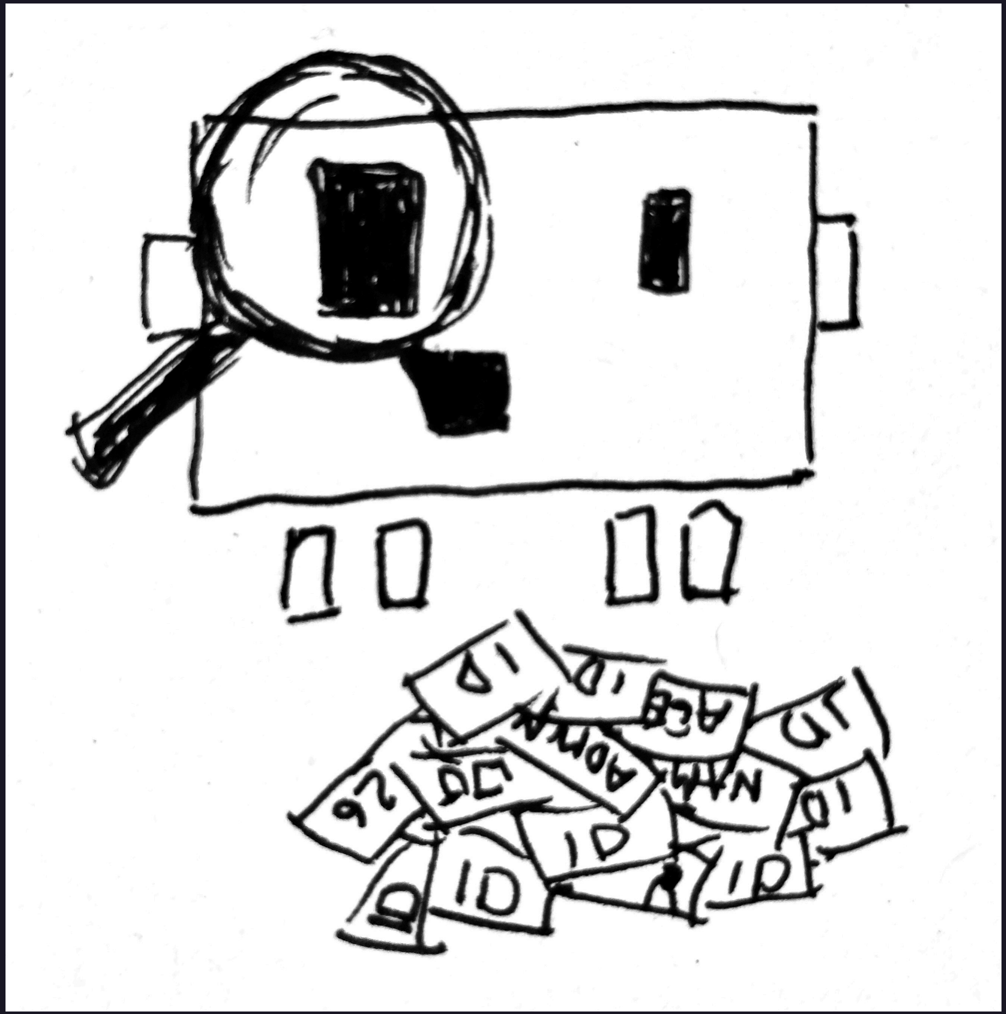
External model

- **Data**
  - Names, emails, stakeholder assignments, reviewer identifiers, document passages copied into prompts, generated summaries that may restate personal data
- **Why sensitive**
  - Leaves the primary application context during model inference (current external-provider path)



Observability traces

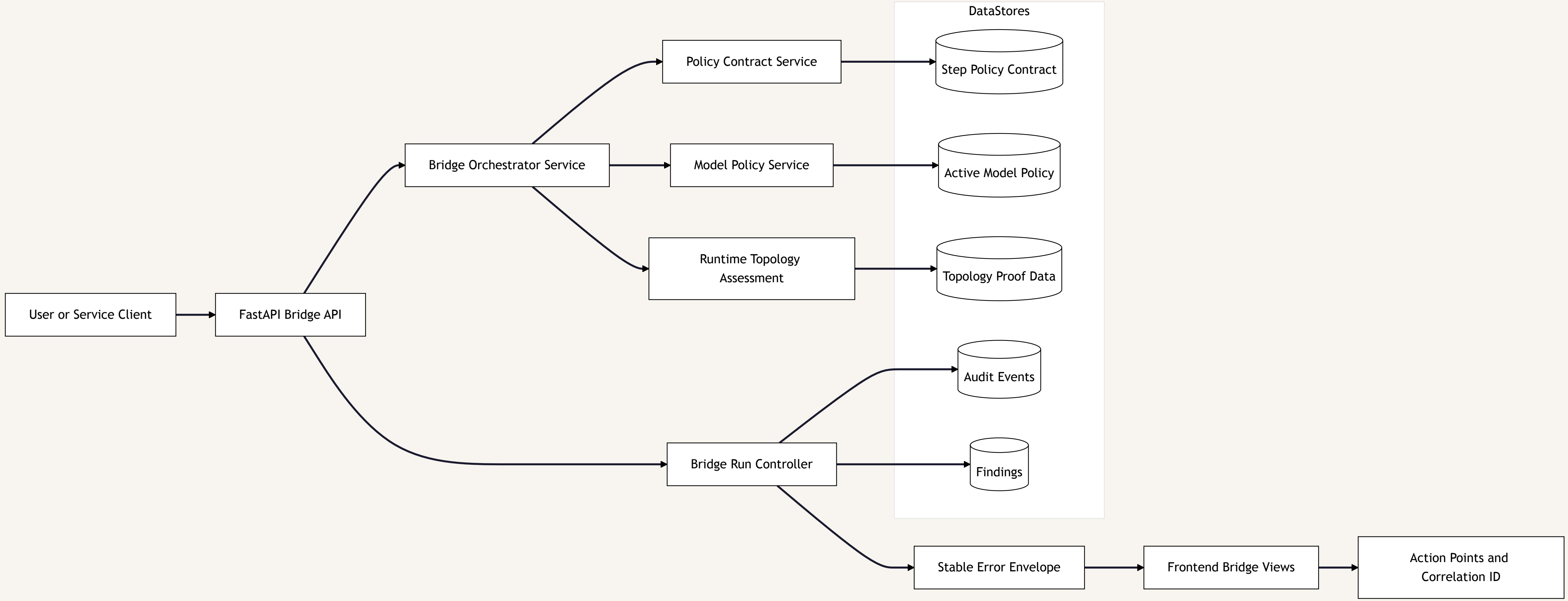
- **Data**
  - `provider`, `model_used`, `trace_id`, `correlation_id`, latency/tokens, rich payload entries, prompt/output snapshots
- **Why sensitive**
  - Enables reconstruction of ***who*** triggered ***what*** model action and ***when***
  - Can become re-identifiable when combined with audit tables



Model credentials

- **Data**
  - API keys, adapter routing flags, provider selection settings
- **Why sensitive**
  - Compromise enables data exfiltration or unauthorized model usage

Mitigation: Bridge egress flow diagram



Mitigation: decision statement about bridge behaviour changes

Contract-first execution

- Model-using steps must pass mandatory policy metadata validation

Personal-data-possible workloads

- Must run on-prem models
- Each model in its own sandbox (containerized)

Auditable outcomes

- Deny/allow paths must be auditable with actionable operator guidance

> The operational model path has shifted **from** remote external GenAI inference **to** locally governed Ollama-based inference for privacy-sensitive workflows, with active model policy and generation parameters controlled through the model-policy admin surface by privileged roles.

Mitigation focus 1: Sensitive data transfer at model boundary

BEFORE

- Potentially personal prompt/output content could be exposed on remote external inference paths.

AFTER

- Bridge privacy-sensitive path is governed toward local Ollama execution.
- Mandatory step policy contract + fail-closed routing denies non-on-prem paths for personal-data-possible steps.
- Runtime readiness gate blocks unsafe execution before run continuation.

Mitigation focus 2: Over-collection and retention in model observability traces

BEFORE

- Rich trace payloads could enable identity/action reconstruction when joined with audit context.

AFTER

- Structured correlation and safe client-envelope filtering are enforced.
- Architecture and DoD retention split controls are defined and tracked.
- Remaining closure: strict retention-class enforcement + redaction-at-write in telemetry stores.

Mitigation focus 3: Model credentials and routing configuration risk

BEFORE

- Compromised provider credentials or unsafe routing configuration could enable unauthorized model usage/exfiltration.

AFTER

- Role-restricted model-policy updates control active model priority and generation parameters.
- Policy/routing deny paths are explicit, actionable, and auditable.
- Remaining closure: dedicated bridge pre-persist secret/token scanner.

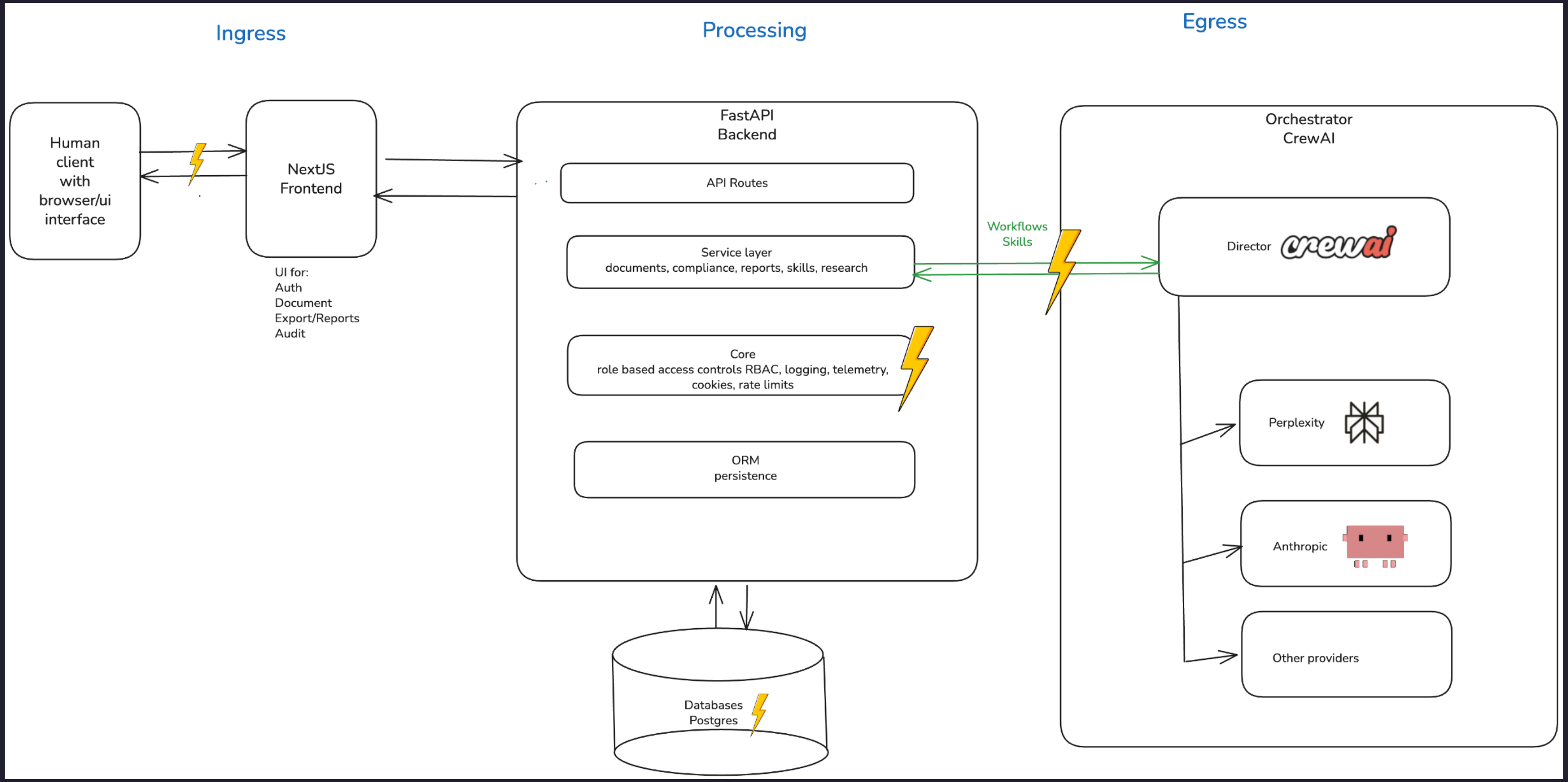
Why this decision

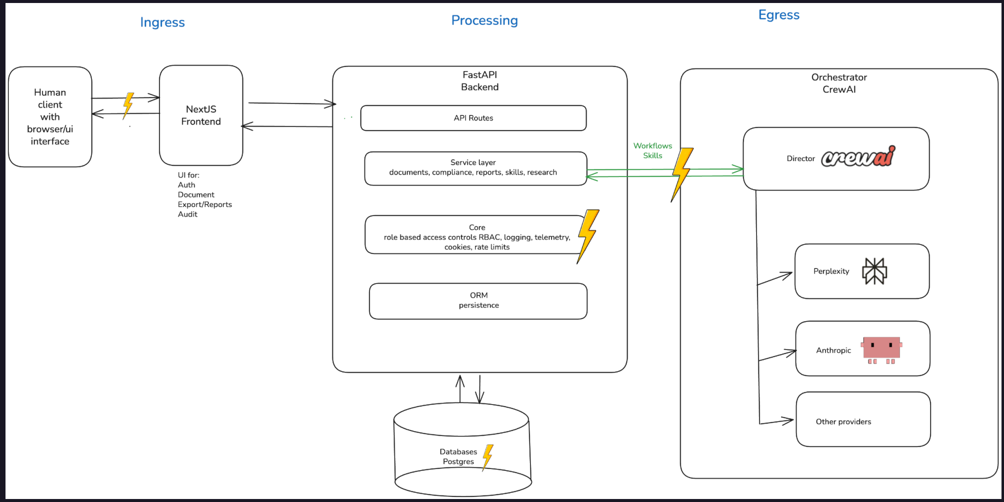
- Privacy risk concentration is highest at model routing boundaries.
- Conventional policy text is insufficient for runtime assurance.
- Compliance requires deterministic controls plus traceable evidence.

IMPLEMENTED ARCHITECTURE CONTROLS

- Step policy contract validation before execution/routing.
- Local Ollama active-model governance with role-restricted parameter updates.
- Fail-closed routing for personal-data-possible workloads.
- Runtime self-check gate with strict/transitional topology proof behavior.
- Audit evidence persistence for both allow and deny paths.
- Stable API error envelope and frontend action-point guidance.
- Mandatory HITL bridge review with persisted decision trail.
- Bridge deny-path evidence includes explicit routing reason and fallback reason coding when applicable.

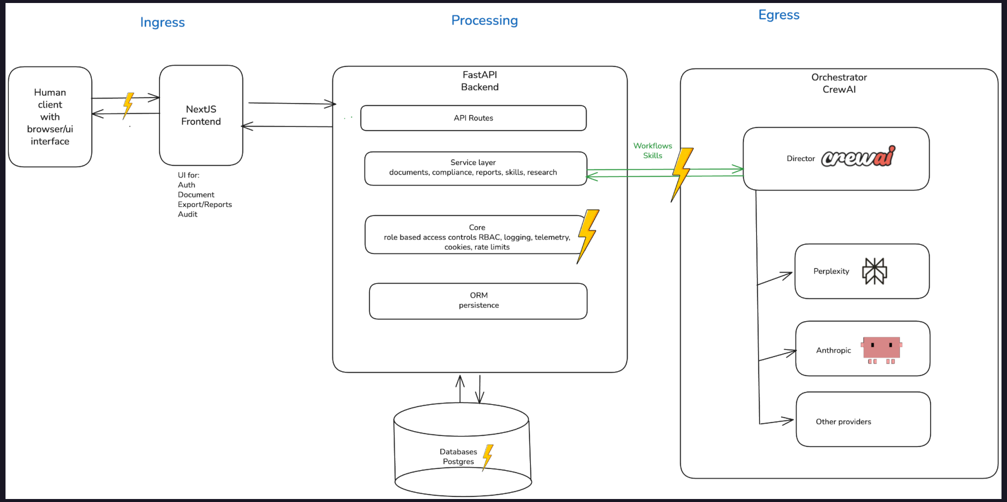
Audit logs/reports and telemetry expose privacy data





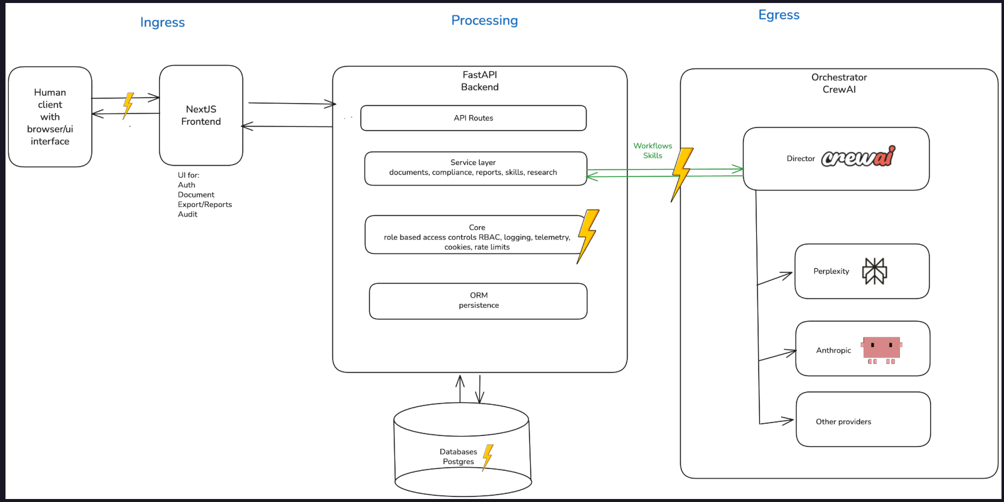
LLM quality observations

- **Data**
  - `payload.provider`, `payload.model_used`, `payload.llm_temperature`
  - `payload.llm_prompt` — document text, stakeholder names, reviewer assignments
  - `payload.llm_output` — compliance summaries that may restate personal context
- **Why sensitive**
  - Prompt context from user documents with names, emails, project identifiers, and business-sensitive content
  - Output may restate that content; both are persisted to a queryable table



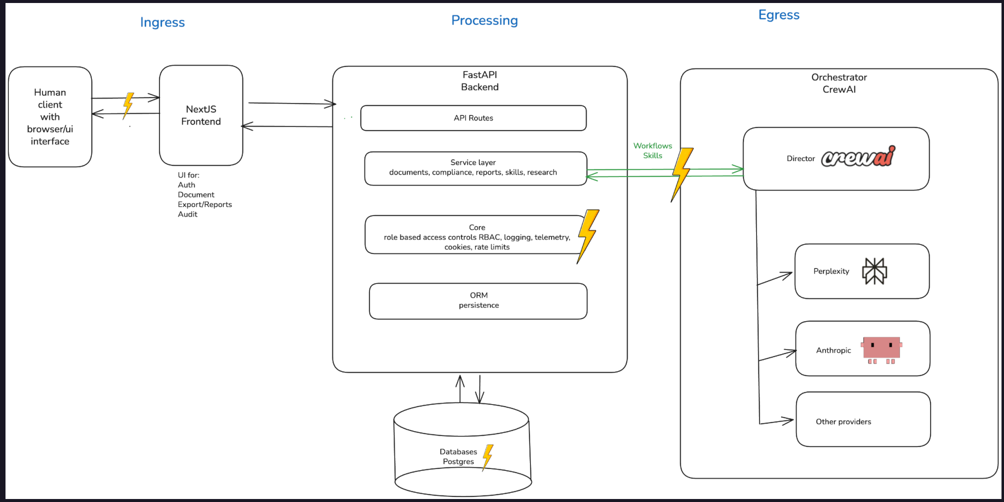
Audit event payload

- **Data**
  - `payload.roles` (user role at login), `payload.remember_me` flag, event-specific context fields, free-form data from orchestrator or Skills API callers
- **Why sensitive**
  - Append-only and intended for long retention
  - No technical control prevents callers from writing personal data into the payload column
  - Combined with `actor_id` (user email) it forms a rich personal profile



OpenTelemetry span attributes

- **Data**
  - HTTP path attribute (e.g., `/api/v1/documents/doc-abc123` — document ID in path), `user_agent`, `http.method`, `http.status_code`, `trace_id` / `span_id`
- **Why sensitive**
  - When `TRACING_EXPORTER=otlp`, path values can embed document or session identifiers
  - User-agent can contribute to fingerprinting



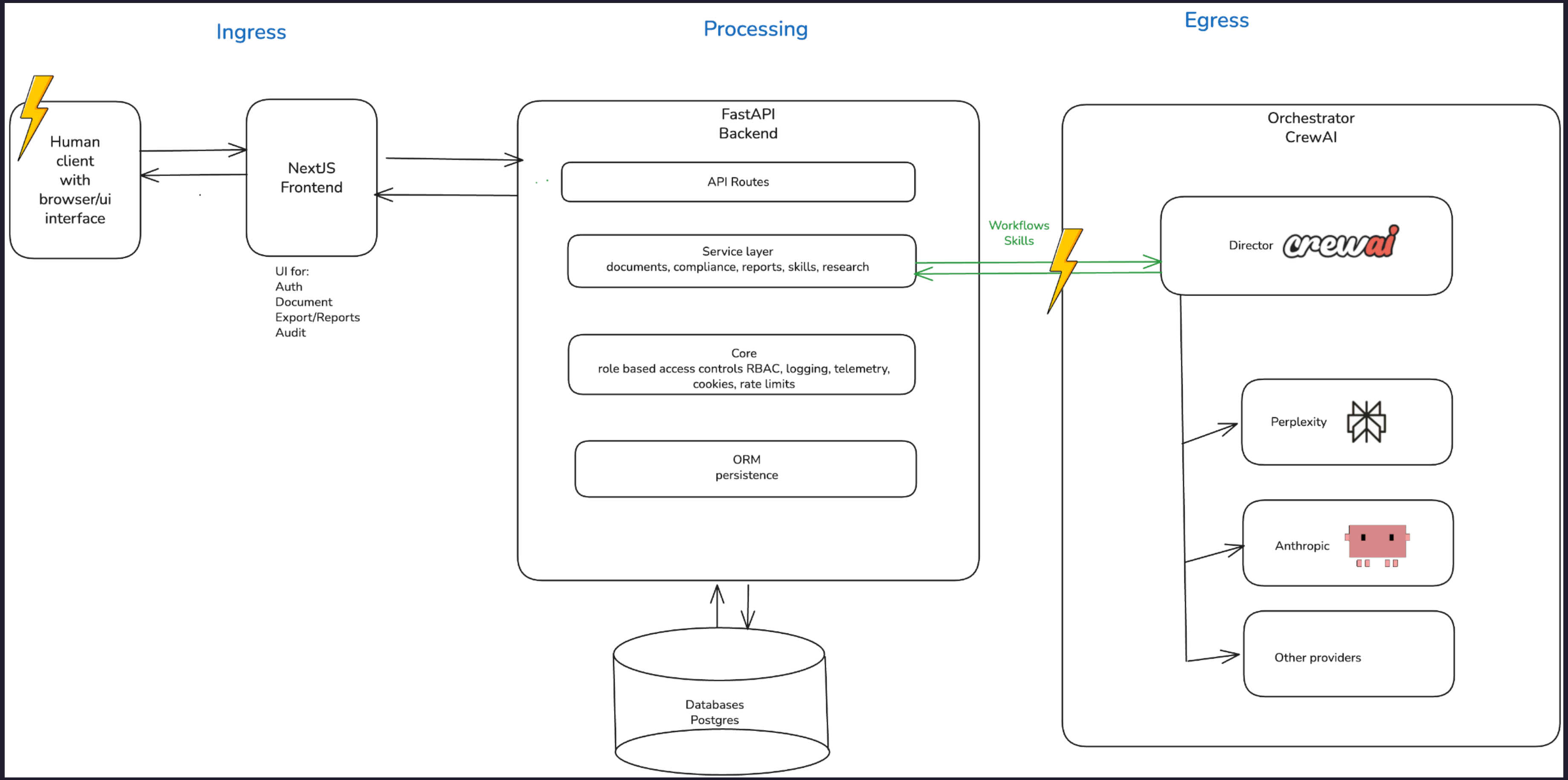
Frontend CSV export

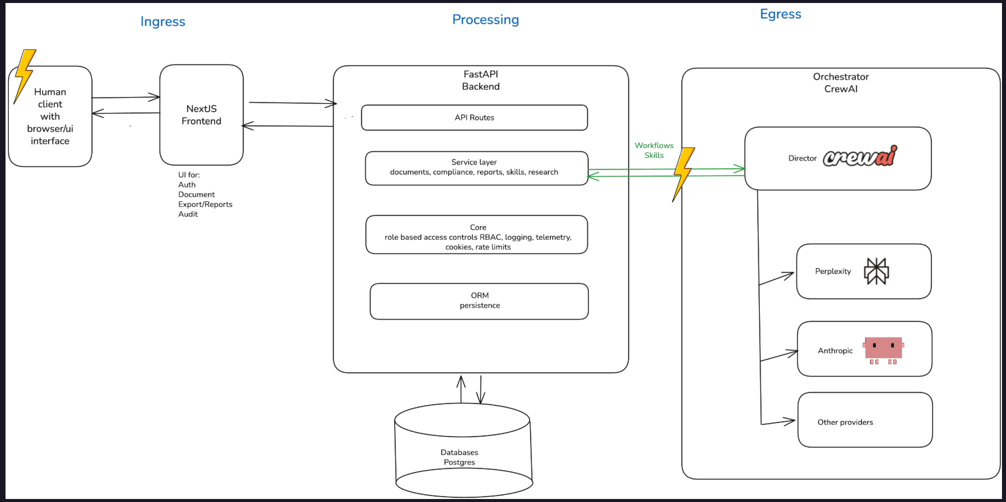
- **Data**
  - Exported observability `prompt_output_pairs.csv` with prompt, output, `source_component`, `trace_id`, timestamps
- **Why sensitive**
  - Created on the user's local filesystem
  - Outside system access controls, retention policy, and audit log
  - May contain personal data from documents processed during the export window

Mitigation: Application telemetry and workflow tracing

- Recommend following OpenTelemetry best practices for handling sensitive data
- Follow the principle of data minimization, where possible.
- While it may not be optimal, try hashing user information and id and delete unhashed data.
- Consider using OTel's `redaction` processor between collection and export
- Apply similar principles to audit logs and reports

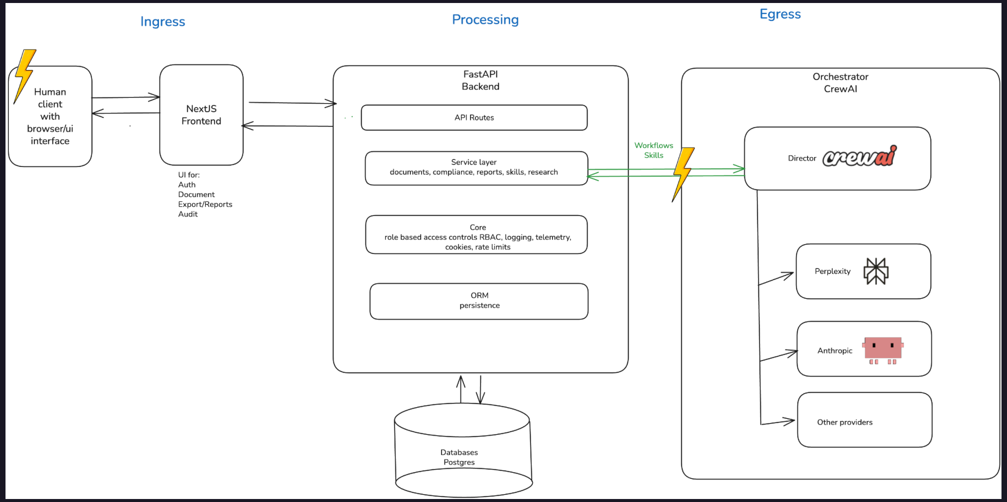
Misconfigured and stale controls give access to private data





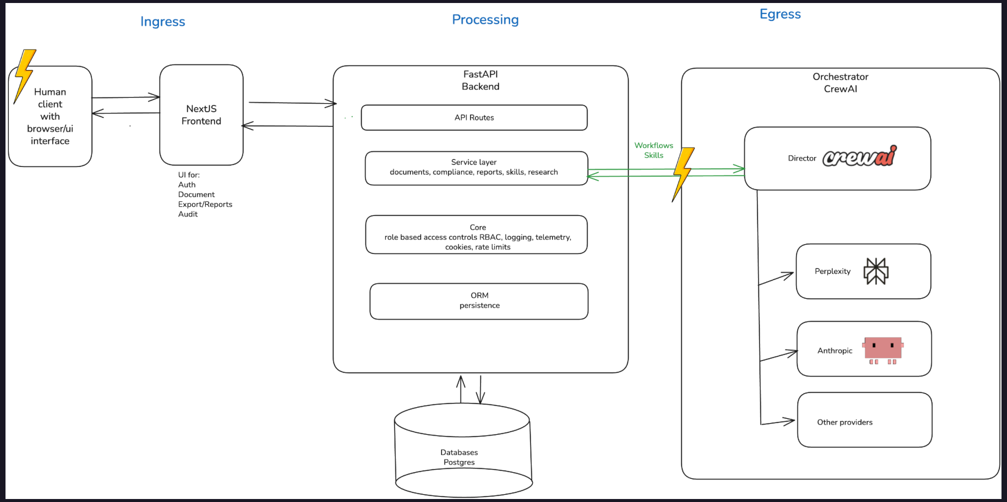
User identity in session store

- **Data**
  - `user_email` (primary identifier), `user_org`, session `session_id`, `expires_at`, `last_seen_at`
- **Why sensitive**
  - Directly identifies users and links organisational role to access patterns and audit trails
  - Retained in PostgreSQL with no visible TTL-based purge policy



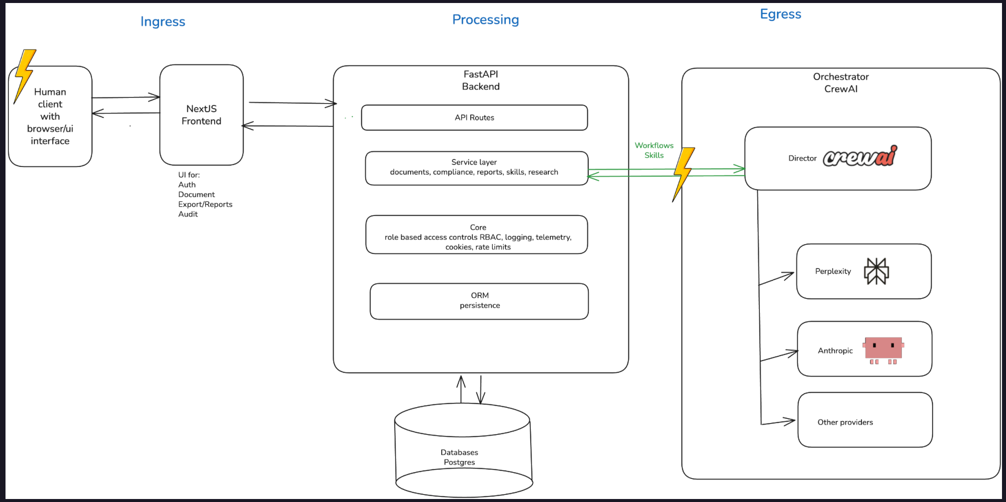
Role assignments and permission scope

- **Data**
  - `user_roles` array per session row (e.g., `["qm_lead"]`, `["auditor"]`), org isolation field `user_org`
- **Why sensitive**
  - Reveals organisational responsibilities and access privileges
  - Can be used for social engineering or targeted attacks
  - GDPR data minimisation applies



Bootstrap/MVP credentials

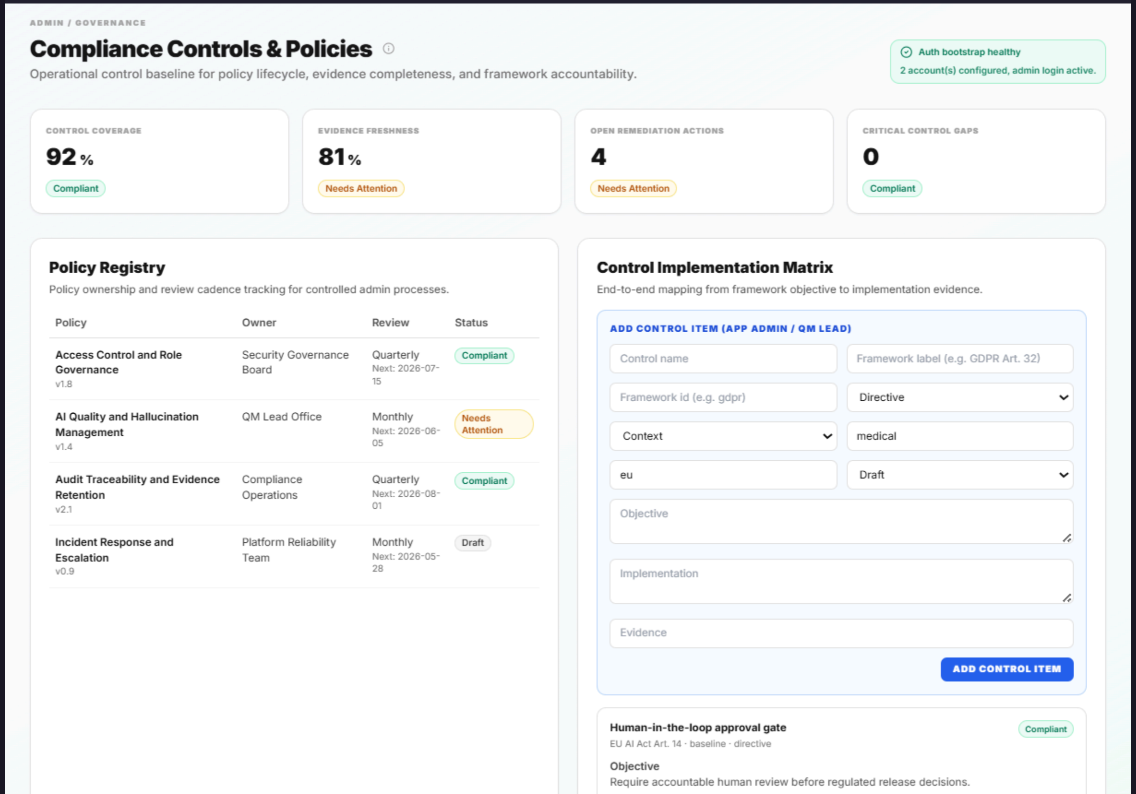
- **Data**
  - `AUTH_MVP_EMAIL`, `AUTH_MVP_PASSWORD`, `AUTH_MVP_ROLES`, `AUTH_MVP_ORG` (env vars)
  - `SECRET_KEY` (API key secret)
- **Why sensitive**
  - Compromise of bootstrap credentials gives attacker a fully provisioned account with configurable roles
  - `SECRET_KEY` grants service-client access to skills and observability

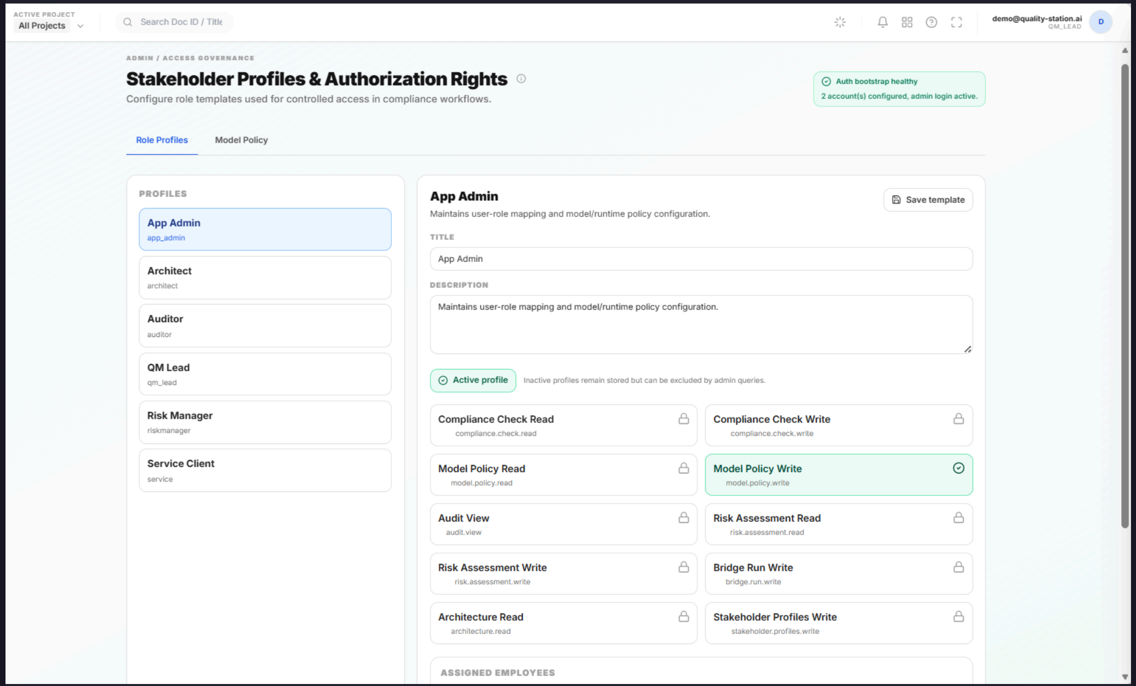


Access decision audit gap

- **Data**
  - Which role accessed which route at what time
  - 403 access denials
  - Service-client route usage with payload summary
- **Why sensitive**
  - Absence of access-decision audit log prevents retrospective investigation of data-access incidents
  - Required for GDPR Art. 30 record of processing activities and breach response

Mitigation: Role-based access controls and GDPR compliance





Recommendations

Top priority going forward

- Harden and refine the bridge behavior use of internal models
- Focus on reducing manual work while meeting the regulatory standards
- Respond to regulatory changes

Why it matters

- Improve ability to analyze 1000 page document by supporting a specialist with deterministic, privacy-conscious tools
- Reduces time for specialists to analyze document from weeks and months
- Adds flexibility to implement changes if directives change
- Reduces the need for expensive specialists to work on repetitive tasks
- Offers basic insights on what has changed, where changed, and policies affected

Fit with company and risk strategy

- Complies with GDPR / BSI in Germany regulations for software rules
- Main regulatory points are addressed in workflow and prepares for external audits

Value created

- Company is prepared for being audited by external agencies
- Cost savings from moving to internal models instead of using external services
- Maximize the human's impact for Human-in-the-loop by reducing toil and increasing time to focus on complex business cases

Questions & answers

- Audit scope and findings
- Risk prioritization and trade-offs
- Mitigations and open items

Thank you

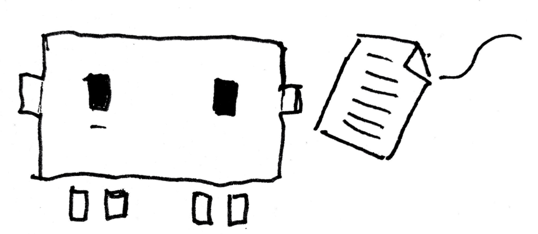
Ilona Brinkmeier · Wiebke Meyer · Carol Willing

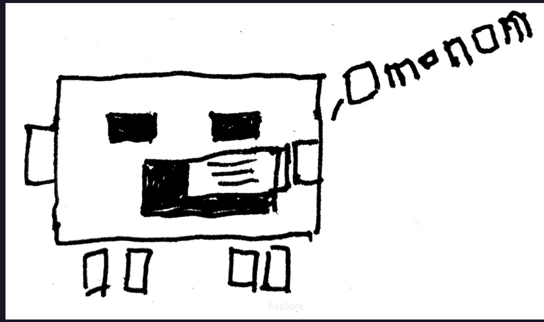
Privacy audit

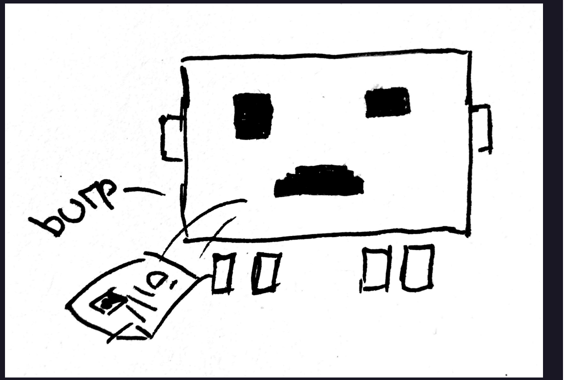
https://willingc.github.io/compliance-checker/

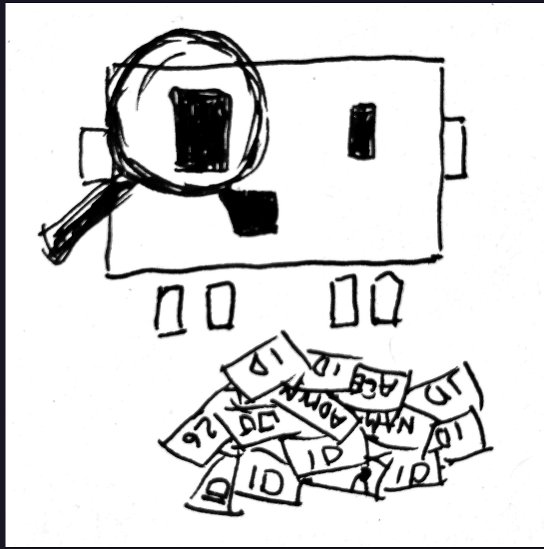
Application

https://github.com/IloBe/doc_quality_compliance_check





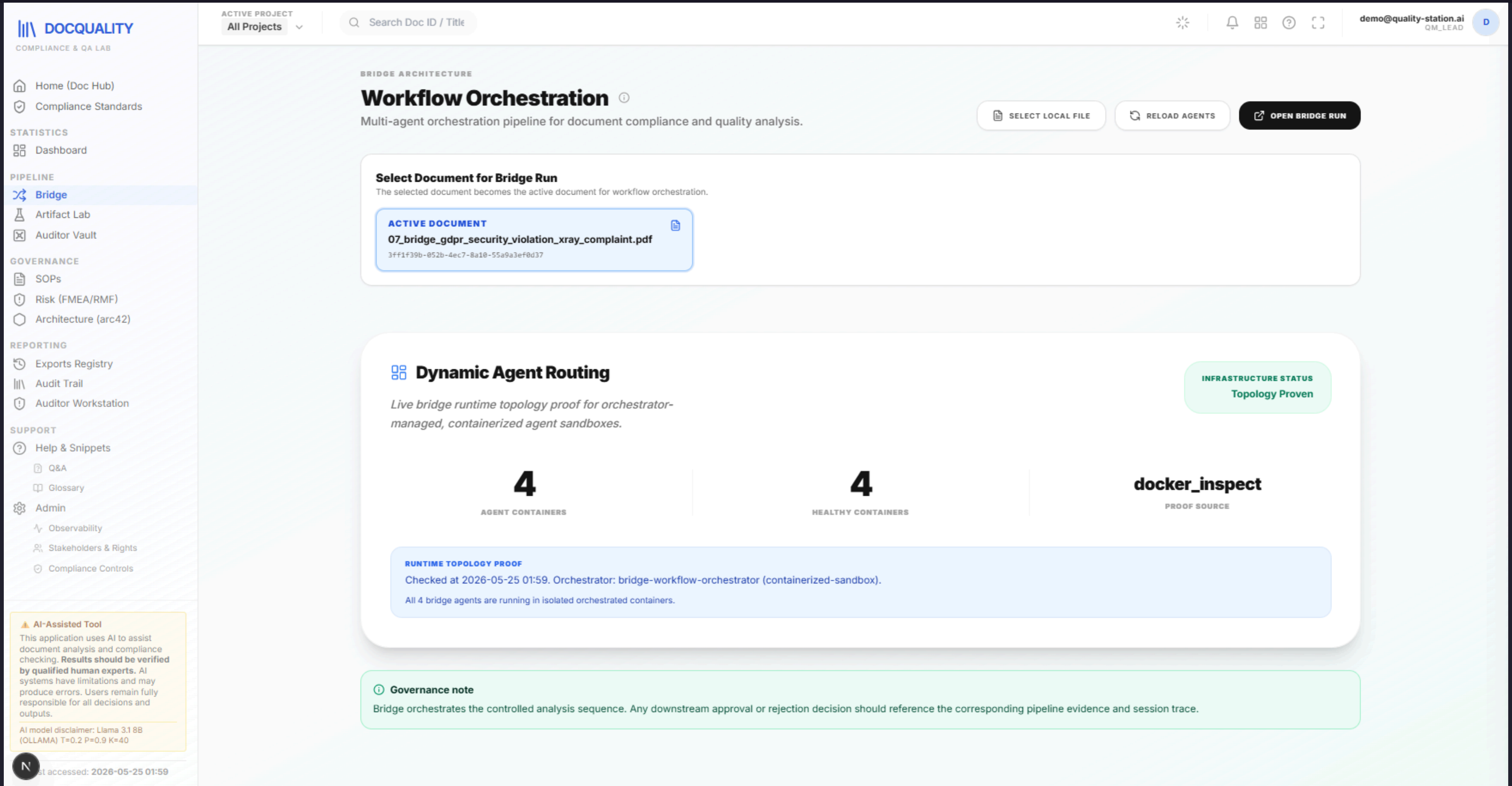




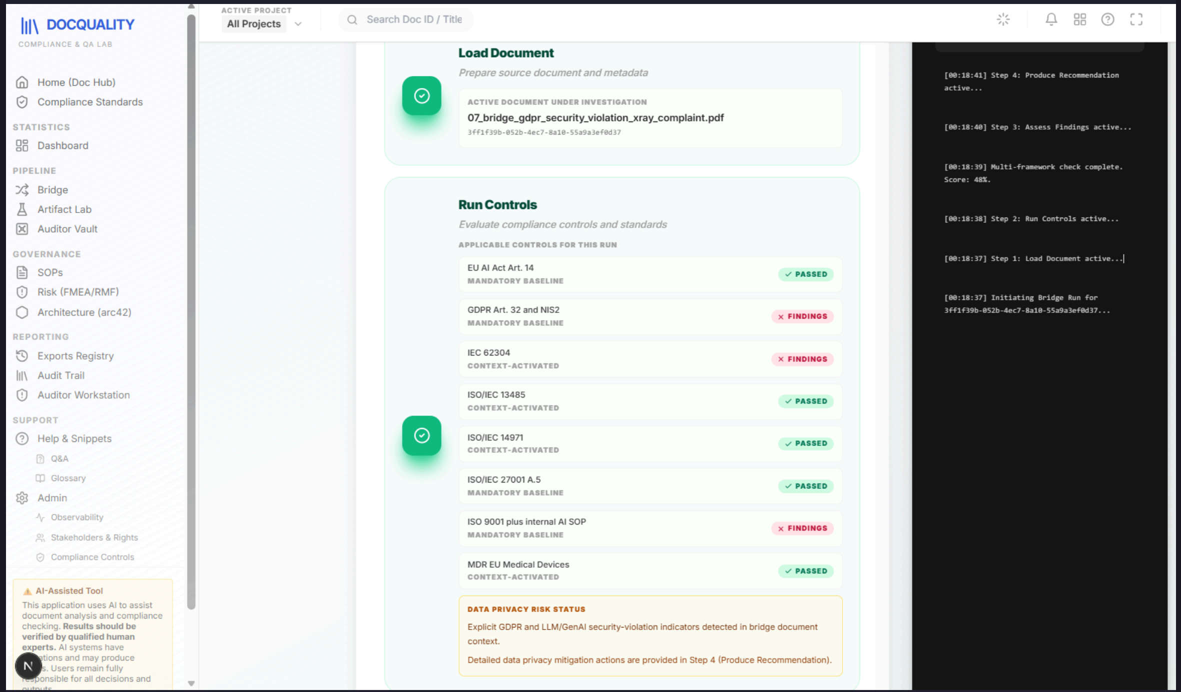
Appendix

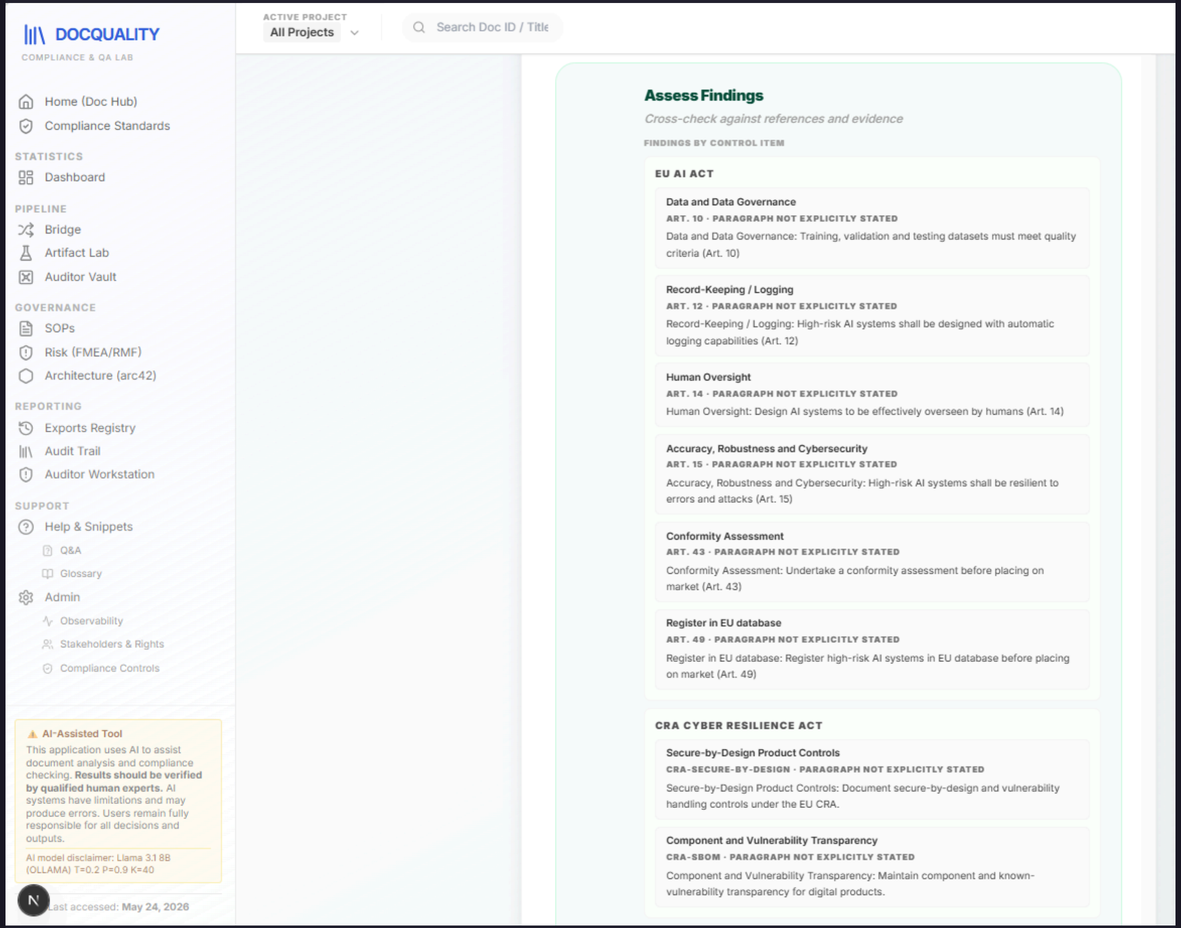
- DocQuality Bridge workflow screens
- DocQuality Admin screens
- DocQuality Compliance standards screens

Bridge workflow — orchestration



Bridge workflow — run steps 1–2





Bridge workflow — run steps 4–4b

Produce Recommendation

Generate decision summary for HITL review

FINAL RESULT SUMMARY

QUALITY GATE SUMMARY - REJECTED

Violations detected. Mandatory gaps: 15. Optional gaps: 1. Privacy violation: yes.

MITIGATIONS FOR FOUND CONTROL ISSUES

Strengthen monitoring and incident response

Add structured logging, alert thresholds, and incident-response playbooks for bridge-critical paths. Attach log samples, alert test evidence, and incident drill results. Affected controls: EUAIA-4 (eu_ai_act), NIS2-REPORTING (nis2).

Update risk-treatment controls

Re-assess identified risks, define treatment owners/due dates, and verify residual-risk acceptance through formal review. Attach risk register updates and governance approval evidence. Affected controls: EUAIA-7 (eu_ai_act), EUAIA-8 (eu_ai_act), EUAIA-9 (eu_ai_act), ISO14971-4 (iso_14971).

Reinforce lifecycle validation evidence

Execute targeted verification and validation for affected components before rerun. Attach test protocol, execution results, and release readiness decision. Affected controls: BSI-TR03185-SDLC-1 (bsi_tr_03185), BSI-TR03185-SDLC-2 (bsi_tr_03185), EUAIA-2 (eu_ai_act), IEC62304-5 (iec_62304) (+1 more).

Close governance and evidence traceability gaps

Update SOP/policy artifacts and map each control to concrete implementation evidence. Attach revised documents, traceability matrix, and review records. Affected controls: BSI-GS-ORP (bsi_grundschutz), CRA-SECURE-BY-DESIGN (cra_cyber_resilience_act), EUAIA-6 (eu_ai_act)

DATA PRIVACY RISK MITIGATION ACTIONS

Apply deterministic PHI/PII redaction before model invocation — PROPOSED

Mask names, addresses, age/sex markers, and hospital identifiers before any LLM/GenAI step.

Planned: enforce pre-inference redaction stage across all sensitive bridge paths.

Enforce local-only sandbox execution for all bridge agent steps — IMPLEMENTED

Run inspection, compliance, research, and quality-gate agents in separate local sandboxes with external egress denied.

Implemented: bridge runtime enforces local ollama-only execution with deny_external egress checks.

Block persistence of raw prompt/output containing sensitive health context — PROPOSED

Store only redacted, schema-validated artifacts and retain full traces only in short-lived restricted stores.

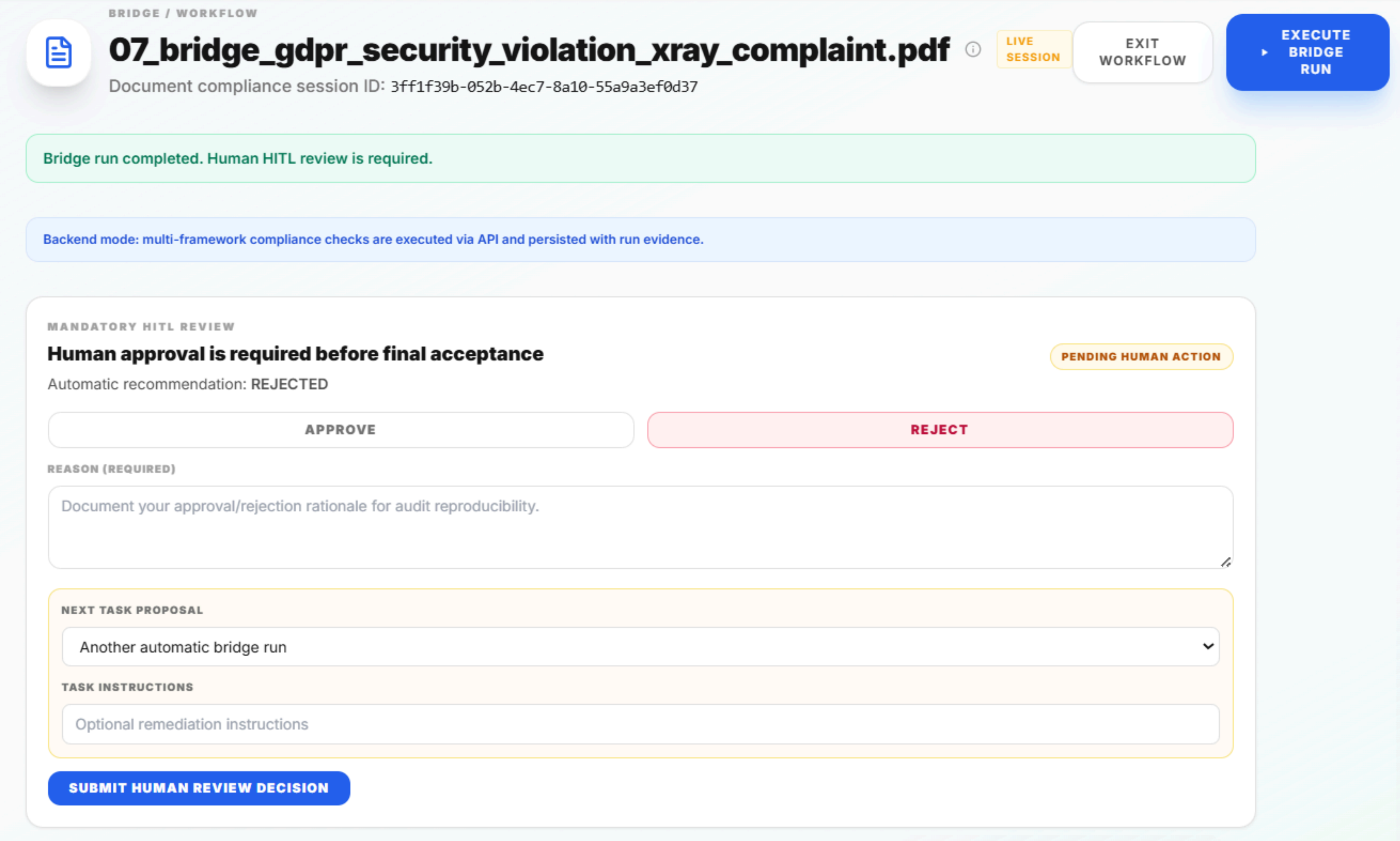
Planned: stricter persistence minimization and retention-tier controls for prompt/output artifacts.

Require human approval for repeated-risk incidents — IMPLEMENTED

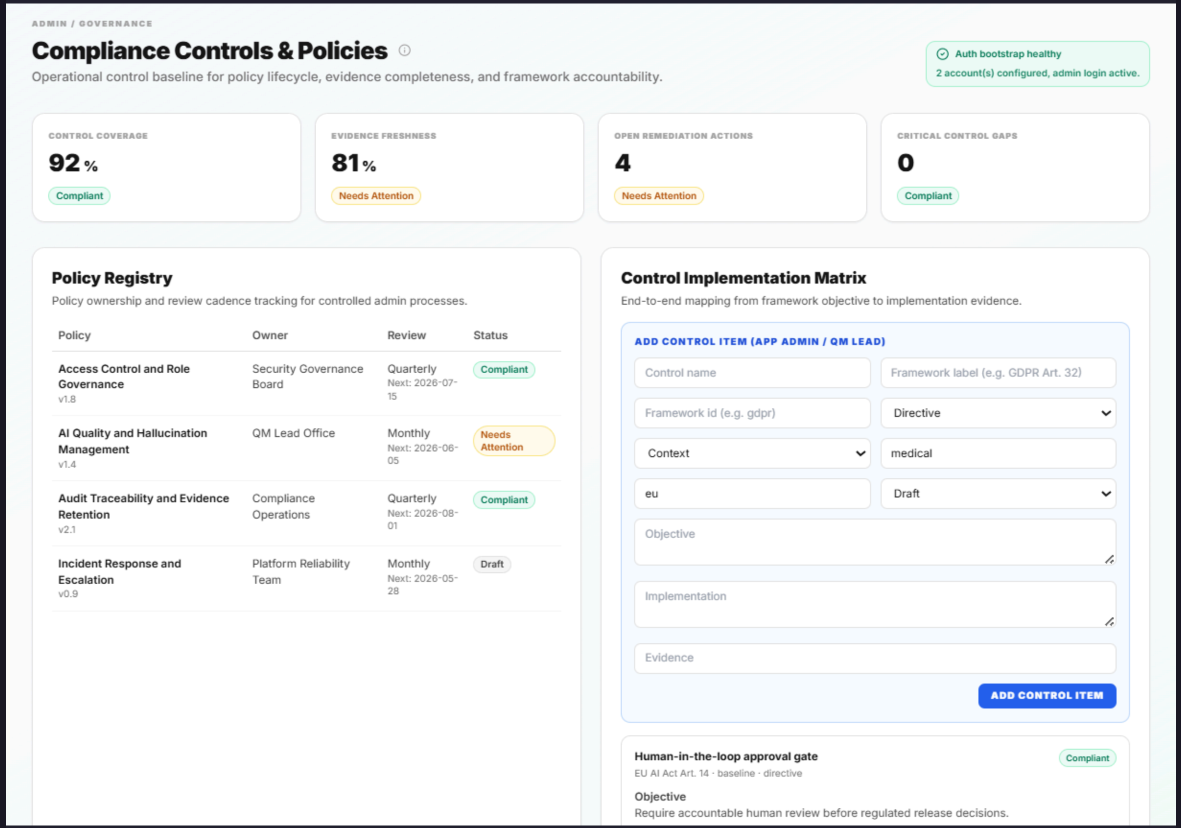
Automatically route bridge runs with repeated mitigation failure to mandatory reviewer rejection/approval workflow.

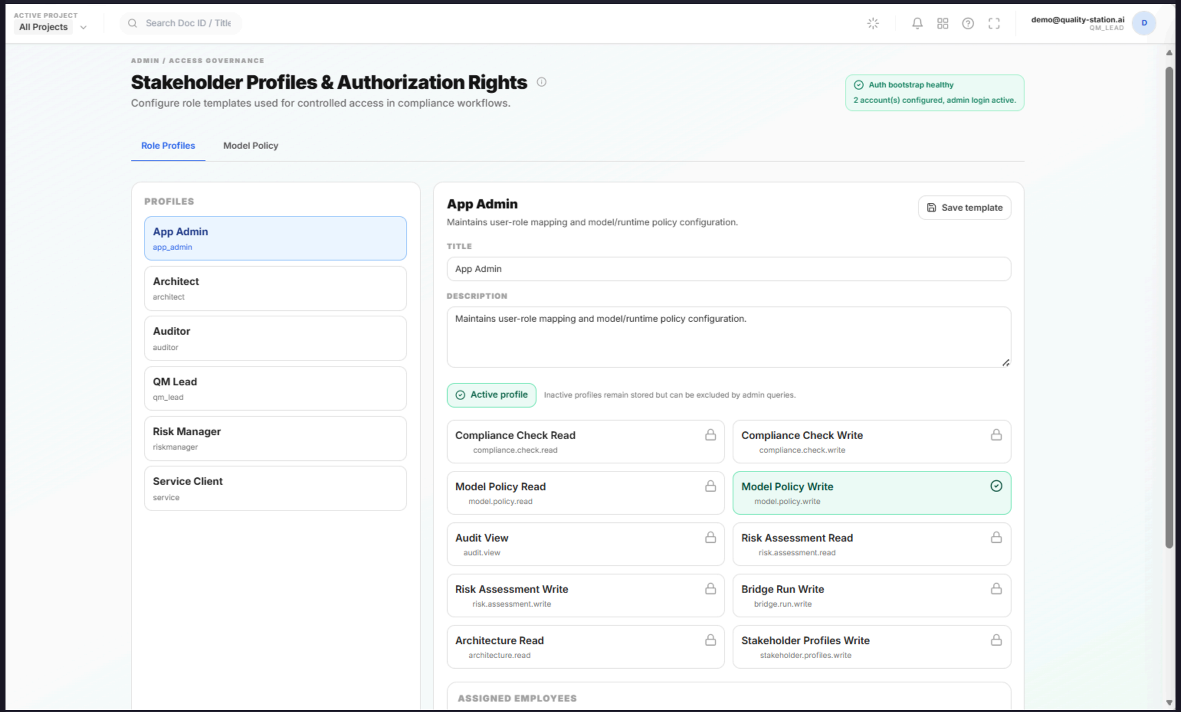
Implemented: bridge runs require mandatory human HITL approval/rejection workflow with auditable decisions.

Bridge workflow — run step 5



Admin — governance & access control





Compliance standards — mandatory & optional